

OOWARE

WEB APPLICATION & API

PENETRATION TEST REPORT

OOSkills Platform

CLIENT / APPLICATION	OOSkills Platform
PRIMARY TARGET	https://ooskills.com
API TARGET	https://api.ooskills.com
ENGAGEMENT	Web Application & API Penetration Testing
ENVIRONMENT	Production
REPORT DATE	05 September 2026
PREPARED BY	OOWare Security Research Team
CLASSIFICATION	Confidential - Security Testing Report

ooware-sec.com

1. Executive Summary

OOWare performed an authenticated web application and API security assessment of the OOSkills platform. Our testing focused on payment enforcement, course-entitlement controls, quiz and examination data exposure, administrative authorization, promo-code visibility, and share-token creation.

We confirmed five security vulnerabilities, including two Critical business-logic and data-exposure issues. The most severe weakness allows any authenticated user to enroll directly in paid courses without creating or paying an order. We also confirmed that the quiz-question API discloses the complete answer key without authentication, including correct answers and explanations.

CRITICAL	HIGH	MEDIUM	LOW
2	1	1	1

Overall Risk

CRITICAL. The current authorization and business-logic controls allow direct revenue loss, public disclosure of the examination answer bank, and unauthorized modification of administrative gamification data. These issues can be exploited using ordinary user accounts or, in the case of quiz-answer disclosure, without authentication.

Business Impact

- Paid courses can be accessed without payment, bypassing the Chargily checkout and order workflow.
- The complete quiz/final-exam answer bank is publicly retrievable, undermining examination and certificate integrity.
- Regular users can create and delete administrative achievement definitions.
- Authenticated users can enumerate promo codes and their discount conditions.
- Users can mint course share tokens without proving entitlement to the course.

Key Recommendation

OOSkills should move entitlement decisions to server-side authorization rules tied to trusted order/payment state. Sensitive answer fields and administrative resources must be protected by explicit role-based permissions, and every object-creation endpoint that grants access or sharing capability should validate the caller's entitlement.

2. Scope and Methodology

WEB APPLICATION	https://ooskills.com
API	https://api.ooskills.com
PRIMARY TEST AREAS	Authentication, authorization, business logic, course access, payments, quizzes, gamification
ACCOUNT LEVEL USED	Regular authenticated USER account; unauthenticated access where applicable
TESTING APPROACH	Manual API request manipulation and authorization validation

Methodology

We manually reviewed application workflows and directly tested API endpoints using authenticated and unauthenticated requests. We compared expected authorization boundaries with actual server behavior, manipulated request sequences to bypass intended business workflows, and validated findings by observing successful server responses and resulting application state.

- Business-logic testing of course enrollment and payment enforcement.
- Broken access control testing across user and admin API endpoints.
- Unauthenticated data exposure testing.
- Authorization and entitlement testing for course sharing functionality.
- Sensitive business-data enumeration testing.

Testing Notes

Testing was limited to the behaviors and endpoints documented in this report. Destructive actions were limited to controlled proof-of-concept objects where possible, such as creating and deleting a test achievement definition.

3. Findings Overview

ID	Severity	Finding	Affected Endpoint
F-01	Critical	Missing Payment/Order Verification on Course Enrollment	POST /api/formation/enrollments/
F-02	Critical	Unauthenticated Disclosure of Quiz Correct Answers	GET /api/formation/quiz-questions/
F-03	High	Broken Access Control on Admin Achievement Definitions	/api/gamification/admin-achievements/
F-04	Medium	Promo Code Details Disclosed to Regular Users	GET /api/formation/promo-codes/
F-05	Low	Unauthorized Share Token Creation for Arbitrary Courses	POST /api/formation/share-tokens/

4. Critical Severity Findings

F-01 Missing Payment/Order Verification on Course Enrollment Endpoint

CRITICAL

CWE-840 - Business Logic Errors • OWASP API5:2023 - Broken Function Level Authorization / Business Logic

Affected endpoint: POST /api/formation/enrollments/

DESCRIPTION

We found that the enrollment endpoint accepts a courseId and immediately creates an active enrollment for the authenticated user, including when the selected course is paid. The server does not verify that an order exists, that the order belongs to the requesting user, or that payment was successfully completed through Chargily before granting course entitlement.

IMPACT

- Any authenticated user can access paid courses without paying.
- Direct loss of course revenue and bypass of the intended checkout workflow.
- Payment provider, promo-code, gift-code, and order-state controls become irrelevant for access enforcement.
- Once the enrollment is created, lesson content gated by enrollment becomes available.

STEPS TO REPRODUCE

1. Authenticate using a normal USER account.
2. Select any paid course ID.
3. Send POST /api/formation/enrollments/ directly with only the courseId.
4. Observe HTTP 201 and an active enrollment without any paid order.

PROOF OF CONCEPT REQUEST

```
POST /api/formation/enrollments/ HTTP/1.1
Host: api.ooskills.com
Authorization: Bearer <valid_jwt>
Content-Type: application/json

{"courseId":"ca24f0f5-fe8c-48d1-892e-c82a340ca8fc"}
```

PROOF OF CONCEPT RESPONSE

```
HTTP/2 201 Created

{
  "id":"7e04b1c3-983f-4076-9e8d-5fc2a3d78317",
  "user":"27ffa73a-aa33-4a1a-9ebb-e8efd847819b",
  "course":"ca24f0f5-fe8c-48d1-892e-c82a340ca8fc",
  "progress":"0.00",
  "status":"active",
  "enrolled_at":"2026-09-05T13:41:59.691388Z",
  "course_title":"Gestion de Projet — Du Besoin à la Livraison"
}
```

ROOT CAUSE

The enrollment creation flow trusts the client-requested courseId and does not require a server-verified paid order for courses where price > 0.

REMEDIATION

- For paid courses, block direct enrollment unless a valid paid order exists for the same user and course.
- Grant enrollment only from a trusted payment-confirmation workflow or idempotent server-side service after verifying Chargily payment status.

- Treat payment-provider callbacks/webhooks as untrusted until cryptographic signature and transaction state are verified.
- Enforce a database-level uniqueness/consistency rule to prevent enrollment without valid entitlement.
- Add automated authorization/business-logic tests covering unpaid, cancelled, failed, refunded, and already-paid order states.

F-02 Unauthenticated Disclosure of Quiz Correct Answers

CRITICAL

CWE-200 - Exposure of Sensitive Information • OWASP API3:2023 - Broken Object Property Level Authorization

Affected endpoint: GET /api/formation/quiz-questions/**DESCRIPTION**

We confirmed that the quiz-question endpoint is publicly accessible without an Authorization header and returns the full question dataset, including options, correct_answer, and explanation. The endpoint exposes the complete answer key for section quizzes and the final examination.

IMPACT

- Any unauthenticated visitor can download the proprietary question bank.
- Students can retrieve correct answers before completing quizzes or the final examination.
- Certificate and XP integrity can be undermined because users can pass assessments without demonstrating knowledge.
- Question-bank confidentiality is lost and the content can be copied or redistributed.

STEPS TO REPRODUCE

1. Send GET /api/formation/quiz-questions/ with no authentication header.
2. Observe HTTP 200 OK.
3. Review returned question objects and confirm correct_answer and explanation are included.
4. Paginate through the endpoint to retrieve the complete dataset.

PROOF OF CONCEPT REQUEST

```
GET /api/formation/quiz-questions/ HTTP/1.1
Host: api.ooskills.com
Accept: application/json
```

PROOF OF CONCEPT RESPONSE

```
HTTP/2 200 OK

{
  "count":300,
  "next":"https://api.ooskills.com/api/formation/quiz-questions/?page=2",
  "results":[
    {
      "id":"555ae84b-...",
      "quiz":"252fce52-...",
      "type":"multiple_choice",
      "question":"The PMBOK 7th Edition shifted from a process-based... How many principles does it define?",
      "options":["8","10","12","15"],
      "correct_answer":1,
      "explanation":"The PMBOK 7th Edition (2021) defines exactly 12 project management principles..."
    }
  ]
}
```

ROOT CAUSE

The quiz-question view does not enforce authentication/authorization, and the student-facing serializer includes answer-key fields that should only be available to trusted grading logic.

REMEDIATION

- Require authentication and enforce course/quiz entitlement before exposing quiz questions.
- Never include correct_answer in question-delivery responses to students.
- Return grading results only after the server evaluates submitted answers.
- Keep explanations hidden until the relevant attempt has been submitted and graded, if explanations are intended to be post-answer feedback.
- Consider rotating/replacing exposed questions if examination integrity is important, because the current question bank should be treated as compromised.

5. High Severity Finding

F-03 Regular Users Can Create and Delete Admin Achievement Definitions

HIGH

CWE-862 - Missing Authorization • OWASP API5:2023 - Broken Function Level Authorization

Affected endpoint: /api/gamification/admin-achievements/

DESCRIPTION

We found that the administrative achievement-definition endpoint accepts write operations from a normal USER-role account. A regular user can create new achievement definitions and delete them. Other administrative endpoints tested, such as promo-code and marketing-campaign management, correctly rejected the same user role, indicating that this endpoint is missing the expected admin authorization control.

IMPACT

- Non-administrative users can modify the platform's gamification configuration.
- Attackers can create arbitrary achievement definitions and potentially manipulate XP rewards or progression rules.
- Legitimate achievements can be deleted, disrupting user experience and gamification integrity.

STEPS TO REPRODUCE

1. Authenticate as a normal user with role USER.
2. POST a new achievement definition to /api/gamification/admin-achievements/.
3. Observe HTTP 201 Created.
4. DELETE the created definition using the returned ID.
5. Observe HTTP 204 No Content.

PROOF OF CONCEPT REQUEST

```
POST /api/gamification/admin-achievements/ HTTP/1.1
Host: api.ooskills.com
Authorization: Bearer <valid_jwt>
Content-Type: application/json

{"key":"hack_test","condition_type":"lessons_completed","condition_value":1}
```

PROOF OF CONCEPT RESPONSE

```
HTTP/2 201 Created

{
  "id":"30c89889-be79-45fa-9287-f0d9698e0aa0",
  "key":"hack_test",
  "icon":"TrophyIcon",
  "xp_reward":20,
  "condition_type":"lessons_completed",
  "condition_value":1,
  "is_active":true
}

DELETE /api/gamification/admin-achievements/30c89889-be79-45fa-9287-f0d9698e0aa0/
HTTP/2 204 No Content
```

ROOT CAUSE

The admin-achievements viewset does not enforce administrator permissions on create/delete write actions.

REMEDIATION

- Apply an explicit administrator-only permission class to all write actions.
- Use deny-by-default authorization on every administrative route.
- Enforce authorization at the server/controller/viewset layer, not only in frontend visibility.
- Add regression tests proving USER accounts receive HTTP 403 for create, update, and delete operations.

6. Medium and Low Severity Findings

F-04 Promo Code Details Disclosed to Regular Users

MEDIUM

CWE-200 - Exposure of Sensitive Information • OWASP API3:2023 - Broken Object Property Level Authorization

Affected endpoint: GET /api/formation/promo-codes/

DESCRIPTION

We found that any authenticated user can list promo-code records using an endpoint whose schema is described as the full/admin view. The response includes the promo code itself, discount type and value, usage limits, validity, minimum order amount, and active state.

IMPACT

- Users can enumerate active discount codes without authorization.
- Attackers can systematically identify the most valuable promo codes and apply them to purchases.
- Business-sensitive campaign rules and discount strategy are exposed.

STEPS TO REPRODUCE

1. Authenticate as a normal USER account.
2. Send GET /api/formation/promo-codes/.
3. Observe HTTP 200 and full promo-code details.

PROOF OF CONCEPT REQUEST

```
GET /api/formation/promo-codes/ HTTP/1.1
Host: api.ooskills.com
Authorization: Bearer <valid_jwt>
```

PROOF OF CONCEPT RESPONSE

```
HTTP/2 200 OK

{
  "count":2,
  "results":[
    {"code":"SUMMER50","discount_type":"fixed","discount_value":"1000.00",
      "max_uses":0,"max_uses_per_user":1,"min_order_total":2000,"is_active":true},
    {"code":"TEST50","discount_type":"percentage","discount_value":"50.00",
      "max_uses":0,"max_uses_per_user":1,"min_order_total":500,"is_active":true}
  ]
}
```

ROOT CAUSE

The read/list action exposes an administrative serializer without applying a corresponding admin-only permission check.

REMEDIATION

- Restrict the administrative promo-code list endpoint to authorized staff/admin roles.
- For user-facing code validation, expose only a dedicated validation endpoint that accepts a candidate code and returns the minimum information needed to apply it.
- Do not disclose all active codes, usage limits, or campaign rules to regular users.

F-05 Any User Can Mint Share Tokens for Courses They Do Not Own

LOW

CWE-639 - Authorization Bypass Through User-Controlled Key • OWASP API1:2023 - Broken Object Level Authorization

Affected endpoint: POST /api/formation/share-tokens/

DESCRIPTION

We found that an authenticated user can create a valid share token for an arbitrary course ID without proving enrollment, purchase, ownership, or another sharing entitlement. The returned token is active and can be consumed by the share-token validation flow.

IMPACT

- Users can create share links for content they have never purchased.
- The issue can facilitate redistribution of course access and compounds the payment-bypass vulnerability.
- Unauthorized token creation increases abuse opportunities even if downstream validation later imposes additional restrictions.

STEPS TO REPRODUCE

1. Authenticate as a normal user.
2. Select a paid course that the user has not purchased.
3. POST the course ID to /api/formation/share-tokens/.
4. Observe HTTP 201 and a valid active token.

PROOF OF CONCEPT REQUEST

```
POST /api/formation/share-tokens/ HTTP/1.1
Host: api.ooskills.com
Authorization: Bearer <valid_jwt>
Content-Type: application/json

{"course_id":"ca24f0f5-fe8c-48d1-892e-c82a340ca8fc","visibility":"token"}
```

PROOF OF CONCEPT RESPONSE

```
HTTP/2 201 Created

{
  "id":"9b523c1f-be48-44f3-bb16-026187d60ea6",
  "course":"ca24f0f5-fe8c-48d1-892e-c82a340ca8fc",
  "course_title":"Gestion de Projet — Du Besoin à la Livraison",
  "token":"9zT_EV46bWh9X8zDEoPunI27lltJk1SzQ-hAaNC2BA",
  "visibility":"token",
  "max_uses":0,
  "uses_count":0,
  "is_active":true,
  "is_valid":true
}
```

ROOT CAUSE

The share-token creation flow validates that the requested course exists but does not validate that the caller is entitled to share that course.

REMEDIATION

- Require active enrollment, ownership, instructor/admin privileges, or another explicit sharing entitlement before token creation.
- Bind the generated token to the authorized creator and permitted sharing scope.
- Apply rate limits and abuse monitoring to share-token creation and validation.
- Revalidate entitlement when the token is consumed if access is sensitive or revocable.

7. Attack Chain and Business Logic Risk

The most significant business risk is not an isolated technical weakness but a broken trust model around entitlement. During testing, we confirmed that course access can be granted directly by calling the enrollment endpoint, independently of the intended order/payment workflow.

- Step 1 - A normal user authenticates to the platform.
- Step 2 - The user identifies the ID of a paid course.
- Step 3 - The user calls POST /api/formation/enrollments/ directly.
- Step 4 - The backend creates an active enrollment without checking a paid order.
- Step 5 - Enrollment-gated lesson content becomes accessible.
- Step 6 - The same user can also create a share token for a course without proving entitlement.

Separately, the unauthenticated quiz-question endpoint makes examination integrity unenforceable from the client side because the correct answers are already disclosed by the server. Fixing frontend behavior alone will not resolve either issue.

8. Remediation Roadmap

Priority	Action	Target
Immediate	Disable direct paid-course enrollment unless a server-verified paid order exists.	Before next release
Immediate	Remove correct_answer from public/student quiz APIs and require entitlement.	Before next release
Immediate	Restrict admin-achievements writes to administrators only.	Before next release
High	Restrict promo-code enumeration and expose only a user-facing validation workflow.	Next release
High	Require entitlement before share-token creation.	Next release
High	Add automated authorization/business-logic regression tests for all five findings.	Next release
Medium	Review all adjacent viewsets for permission-class inconsistencies and serializer overexposure.	1-2 release cycles

9. Conclusion

OOWare confirmed two Critical, one High, one Medium, and one Low vulnerability in the OOSkills web application/API. The two Critical findings directly affect the platform's core business model and certification integrity: paid-course access can be obtained without payment, and the complete quiz answer bank is available without authentication.

The root pattern across the report is insufficient server-side authorization around sensitive business actions and data. We recommend prioritizing payment-linked entitlement enforcement and quiz-answer confidentiality, followed immediately by a systematic review of role-based permissions across administrative and sharing endpoints.

After remediation, OOWare recommends a focused retest of all affected endpoints, including negative cases for unpaid/cancelled/refunded orders, student quiz access before and after submission, regular-user access to every admin viewset, promo-code visibility, and share-token creation/consumption.

OOWARE SECURITY RESEARCH TEAM

ooware-sec.com